7 DE JULIO DE 2022

Reporte pentesting

elultimo&mevoy.com

JUAN ANTONIO SUÁREZ SUÁREZ
CHT
MADRID

Reporte pentesting elultimo&mevoy.com

Index

1. Introducción
2. Scope/gathering
3. Identified Vulnerabilities
4. Recomendación
5. Conclusiones

Elultimoymevoy.com es un proyecto creado por compañeros de Keepcoding, es un blog donde se puede escribir, crear y compartir conocimiento asociados a lenguajes de programación.

Nuestro scope/target será la dirección https://elultimoymevoy.com

Primero realizaremos una recogida de información para averiguar direcciones ip,subdominios,dns ... etc.

Nmap

nmap -sS -Pn -sV -sC -O -p0- -vv --open --reason -T4 -oA output_nmap elultimoymevoy.com

elultimoymevoy(3.70.140.211)

Para nuestra pagina del pentesting usaremos una herramienta avanzada que contiene varias herramientas en si, reconftw. Para nuestro caso usamos el siguiente comando:

./reconftw.sh -d elultimoymevoy.com -a

Se nos almacenara todo lo que recoja en nuestra carpeta recon, lleva un rato completar el escáner completo.

```
www.elultimoymevoy.com - 217.70.184.56
api.elultimoymevoy.com - 3.70.140.211
```

```
Domain Name: ELULTIMOYMEVOY.COM
Registry Domain ID: 2685642841_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.gandi.net
Registrar URL: http://www.gandi.net
Updated Date: 2022-03-30T21:42:20Z
Creation Date: 2022-03-30T21:42:19Z
Registry Expiry Date: 2023-03-30T21:42:19Z
Registrar: Gandi SAS
Registrar IANA ID: 81
Registrar Abuse Contact Email: abuse@support.gandi.net
Registrar Abuse Contact Phone: +33.170377661
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NS-19-A.GANDI.NET
Name Server: NS-215-B.GANDI.NET
Name Server: NS-27-C.GANDI.NET
```

```
[tech-detect:express] [http] [info] https://api.elultimoymevoy.com:443
[tech-detect:nginx] [http] [info] https://api.elultimoymevoy.com:443
[tech-detect:nginx] [http] [info] https://elultimoymevoy.com:443
[tech-detect:nginx] [http] [info] https://elultimoymevoy.com/
[tech-detect:nginx] [http] [info] https://webmail.eu.com
[http-missing-security-headers:strict-transport-security] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:access-control-allow-credentials] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:access-control-allow-headers] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:content-security-policy] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:permission-policy] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:x-frame-options] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:x-content-type-options] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:access-control-expose-headers] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:access-control-max-age] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:access-control-allow-methods] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:referrer-policy] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:clear-site-data] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] https://api.elultimoymevoy.com:443
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] https://elultimoymevoy.com:443
[http-missing-security-headers:access-control-allow-credentials] [http] [info] https://elultimoymevoy.com:443
[http-missing-security-headers:access-control-expose-headers] [http] [info] https://elultimoymevoy.com:443
[http-missing-security-headers:x-frame-options] [http] [info] https://elultimoymevoy.com:443
```

Archivo Editar Buscar Ver Documento Ayuda

portscan_passive.txt | subs_ips_vhosts.txt

```
1 217.70.184.56 www.elultimoymevoy.com
2 3.70.140.211 api.elultimoymevoy.com
3 3.70.140.211 elultimoymevoy.com
```

```
1 https://api.elultimoymevoy.com:443
2 https://elultimoymevoy.com:443
3 https://webmail.elultimoymevoy.com:443
4 https://www.elultimoymevoy.com:443
5
```

```
1
2 ; <<>> DiG 9.18.1-1-Debian <<>> axfr elultimoymevoy.com @ns-19-a.gandi.net.
3 ;; global options: +cmd
4 ; Transfer failed.
5
6 ; <<>> DiG 9.18.1-1-Debian <<>> axfr elultimoymevoy.com @ns-27-c.gandi.net.
7 ;; global options: +cmd
8 ; Transfer failed.
9
10 ; <<>> DiG 9.18.1-1-Debian <<>> axfr elultimoymevoy.com @ns-215-b.gandi.net.
11 ;; global options: +cmd
12 ; Transfer failed.
13
```

Realiza comprobación de zone transfer, ips y dns además de usar nuclei, esta ultima tiene un repositorio con varios tipos de vulnerabilidades web.

Puredns.

Tras el uso de esta herramienta podemos observar como nos devuelve diferentes dominios validos, podemos usar una permutación del primer resultado para posteriormente lanzar otro puredns, en este caso solo nos da un resultado mas con poca relevancia. Gotator será nuestra herramienta para las permutaciones. El comando de puredns :

puredns bruteforce wordlist.txt example.com -r resolvers.txt -w output.txt

(la wordlist utilizada se han extraído del repositorio de github de SecLists)

Comando de gotator adjuntado en la imagen

Y por ultimo.

puredns resolve gotator1.txt -r resolverstop.txt

```
Found 3 valid domains:
www.elultimoymevoy.com
webmail.elultimoymevoy.com
api.elultimoymevoy.com
```

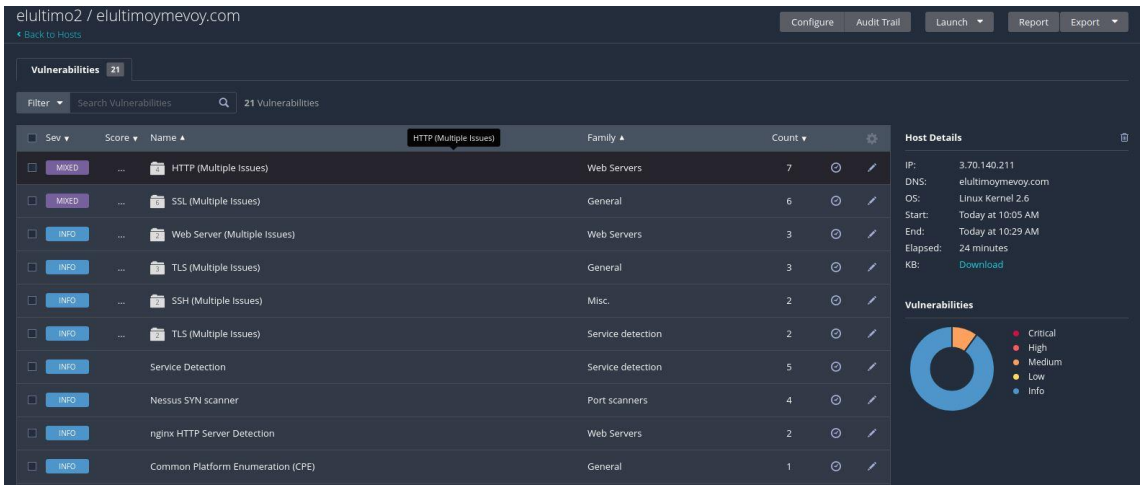
```
┌──(juan㉿kali)-[~]
└─$ gotator -sub subdomain-elultimo.txt -perm /usr/share/seclists/Discovery/DNS/deepmagic.com-prefixes-top500.txt -depth 1 -numbers 10 -mindup -adv -md > gotator1.txt

GOTATOR

> By @JosueEncinar
> Version 1.1
> Tool to generate DNS wordlists through permutations.

[i] Working in progress
```

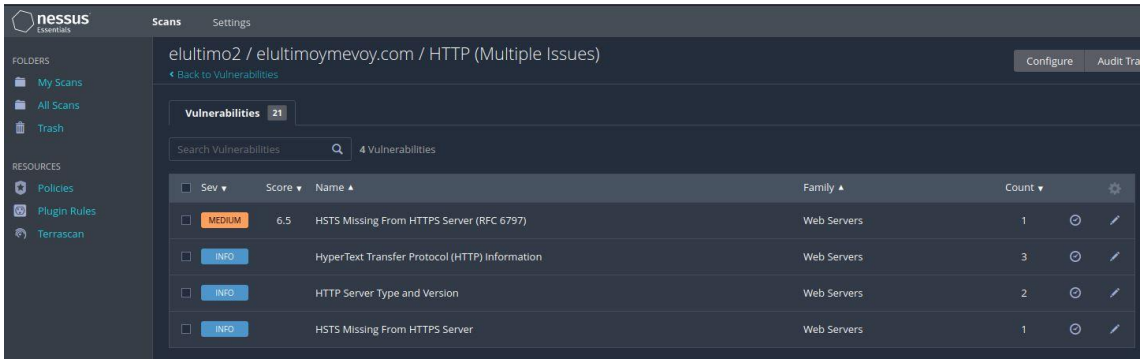
```
Found 4 valid domains:
api.elultimoymevoy.com
www.elultimoymevoy.com
elultimoymevoy.com
webmail.elultimoymevoy.com
```

Identified Vulnerabilities

Para identificar las vulnerabilidades hemos usado el escaner de Nessus essentials, burp suite y herramienta de Python.

Nessus





En nuestro escaner no aparece ninguna vulnerabilidad critica/alta, todas relacionadas con la información y un posible mitm usando un downgrade por no tener establecida la opción HSTS.

Reconftw

vulnerabilidades asociadas a las CVE

```
Testing vulnerabilities

Heartbleed (CVE-2014-0160)                not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224)                       not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experiment.  not vulnerable (OK), no session ticket extension
ROBOT                                     Server does not support any cipher suites that use RSA key transport
Secure Renegotiation (RFC 5746)           supported (OK)
Secure Client-Initiated Renegotiation     not vulnerable (OK)
CRIME, TLS (CVE-2012-4929)                not vulnerable (OK)
BREACH (CVE-2013-3587)                    potentially NOT ok, "gzip" HTTP compression detected. - only supplied "/" tested
                                          Can be ignored for static pages or if no secrets in the page
POODLE, SSL (CVE-2014-3566)               not vulnerable (OK)
TLS_FALLBACK_SCSV (RFC 7507)              No fallback possible (OK), no protocol below TLS 1.2 offered
SWEET32 (CVE-2016-2183, CVE-2016-6329)    not vulnerable (OK)
FREAK (CVE-2015-0204)                     not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703)      not vulnerable on this host and port (OK)
                                          no RSA certificate, thus certificate can't be used with SSLv2 elsewhere
LOGJAM (CVE-2015-4000), experimental      common prime with 2048 bits detected: RFC7919/ffdhe2048 (2048 bits),
                                          but no DH EXPORT ciphers
BEAST (CVE-2011-3389)                     not vulnerable (OK), no SSL3 or TLS1
LUCKY13 (CVE-2013-0169), experimental     potentially VULNERABLE, uses cipher block chaining (CBC) ciphers with TLS. Check patches
Winshock (CVE-2014-6321), experimental    not vulnerable (OK)
RC4 (CVE-2013-2566, CVE-2015-2808)        no RC4 ciphers detected (OK)
```

Burp Suite

Primero nos hemos creado un usuario en la pagina web, para ver las cabeceras y la información, así como posibles tokens o cookies.

Request

Pretty Raw Hex

```
1  POST /login HTTP/1.1
2  Host: api.elultimoymevoy.com
3  Content-Length: 59
4  Sec-Ch-Ua: " Not A;Brand";v="99", "Chromium";v="96"
5  Accept: application/json, text/plain, */*
6  Content-Type: application/json
7  Sec-Ch-Ua-Mobile: ?0
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
   AppleWebKit/537.36 (KHTML, like Gecko) Chrome/96.0.4664.45
   Safari/537.36
9  Sec-Ch-Ua-Platform: "Linux"
10 Origin: https://elultimoymevoy.com
11 Sec-Fetch-Site: same-site
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://elultimoymevoy.com/
15 Accept-Encoding: gzip, deflate
16 Accept-Language: es-ES,es;q=0.9
17 Connection: close
18
19 {
     "email":"pocholo9519@hotmail.com",
     "password":"Pocholo95@"
   }
```

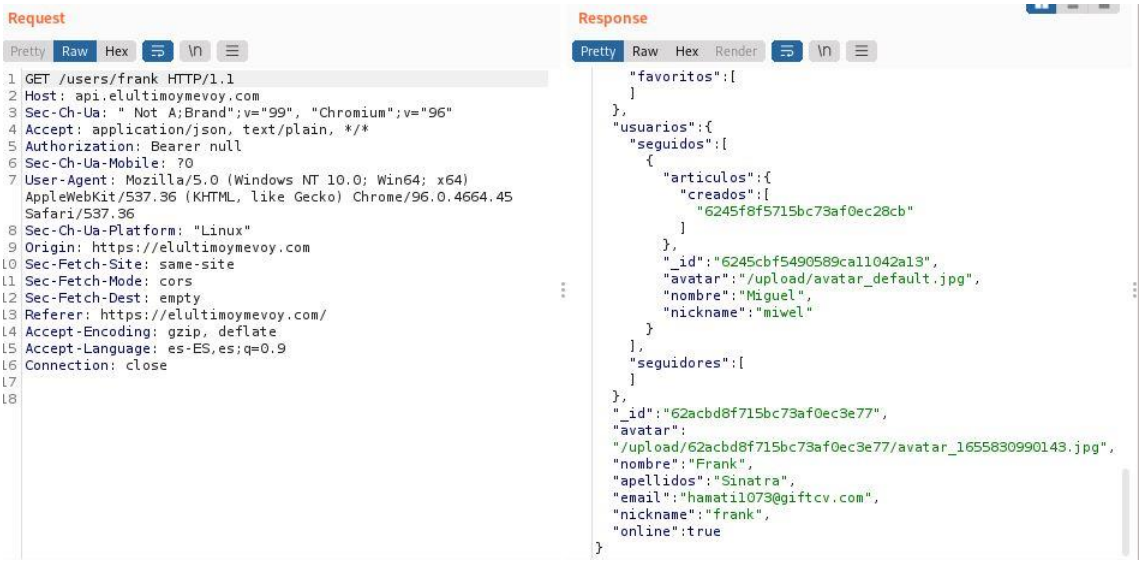
Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Server: nginx
3  Date: Thu, 07 Jul 2022 05:39:39 GMT
4  Content-Type: application/json; charset=utf-8
5  Content-Length: 208
6  Connection: close
7  X-Powered-By: Express
8  Access-Control-Allow-Origin: *
9  ETag: W/"d0-9XCGCEXxk/Vi750B5GXYZuh0N+I"
10
11 {
     "token":
     "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjYyYzVhNTI2M2
     Y2ZjNiNDhmYjU3ODJiNyIsIm5pY2tuYWllIjoicG9jaG8iLCJpYXQiOjE2NT
     cxNzIzNzksImV4cCI6MTY1Nzc3NzE3OX0.7KW6TNbku-vjUGhh8Nj4616Xwp
     f9it5WcK8MCDoc3H0"
   }
```

En este caso vemos como nos aparece tanto nuestro perfil como la password, en la respuesta del servidor nos manda el token para nuestro id de usuario.

Además si visitamos la pagina de algún usuario la respuesta nos da el id y correo usado por el usuario,en este caso tenemos a Frank Sinatra, nos muestra usuarios seguidos y su id.



A01:2021 – Broken Access Control

En nuestra segunda parte nos hemos creado otro usuario, hemos utilizado un correo de 10minutesmail y podemos ver que la pagina no tiene ningún proceso de verificación mandando un correo, por ejemplo.

Nuestro usuario vuln que será el atacante

Dentro de la pagina con nuestro usuario vuln vamos a usar una petición /editar/id_articulo, en este caso elegimos un articulo creado por nuestro primer usuario registrado, usando el /editar/ nos redirige al articulo del que tengamos la id y accedemos a la pagina de editar, para poder editar el articulo nos hace falta el token que nos apareció unas peticiones atrás. Como se ve en la siguiente imagen hemos modificado el texto del apartado contenido añadiéndole un omgsoyvuln.

```
17 Accept-Language: es-ES,es;q=0.9
18 Connection: close
19
20 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
21 Content-Disposition: form-data; name="titulo"
22
23 g
24 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
25 Content-Disposition: form-data; name="textoIntroductorio"
26
27 ggomgsoyvuln
28 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
29 Content-Disposition: form-data; name="contenido"
30
31 <p>html</p>
32 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
33 Content-Disposition: form-data; name="fechaPublicacion"
34
35 2022-07-07T06:05:16.824Z
36 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
37 Content-Disposition: form-data; name="categorias"
38
39 html
40 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
41 Content-Disposition: form-data; name="archivoDestacado"
42
43 null
44 ------WebKitFormBoundarydXSiAMyhIUCHyTVA--
45
```

La peticion se procesa y nos aparecera un header PATCH con el articulo y en el apartado authorization nos aparece el token de nuestro usuario atacante, si intercambiamos el token que aparece resaltado por el otro token de pocholo que es el creador del articulo tendremos autorizacion, mandamos las peticiones y nos modifica el articulo sin haberlo escrito con nuestro usuario vuln.

```
Pretty  Raw  Hex  ⇄  \n  ≡
1  PATCH /articles/62c5b9b53f6f3b48fb5784a5 HTTP/1.1
2  Host: api.elultimoymevoy.com
3  Content-Length: 697
4  Sec-Ch-Ua: " Not A;Brand";v="99", "Chromium";v="96"
5  Accept: application/json, text/plain, */*
6  Content-Type: multipart/form-data;
   boundary=----WebKitFormBoundarydXSiAMyhIUCHyTVA
7  Authorization: Bearer
   eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjYyYzY3NjY5M2Y2
   ZjNiNDhmYjU3ODhmMyIsIm5pY2tuYW1lIjoidnVsbiIsImlhdCI6MTY1NzE3M
   zclOSwiZXhwIjoxNjU3Nzc4NTU5fQ.ZBd17lHr0844eQDwHTJdaV6UMDAObJs
   CCvShkDLcNug
8  Sec-Ch-Ua-Mobile: ?0
9  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
   AppleWebKit/537.36 (KHTML, like Gecko) Chrome/96.0.4664.45
   Safari/537.36
10 Sec-Ch-Ua-Platform: "Linux"
11 Origin: https://elultimoymevoy.com
12 Sec-Fetch-Site: same-site
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://elultimoymevoy.com/
16 Accept-Encoding: gzip, deflate
17 Accept-Language: es-ES,es;q=0.9
18 Connection: close
19
20 ------WebKitFormBoundarydXSiAMyhIUCHyTVA
21 Content-Disposition: form-data; name="titulo"
```

INFORMATION LEAK

También podemos intentar tirar mas del hilo, realizando fuerza bruta para sacar otros tokens después de averiguar como se generan los token, están codificados en base64, vemos que utilizan los campos de id y nickname junto a otros dos de los que no hemos podido sacar información. (information leak) acerca de un usuario, con un simple decode podemos leer el token payload.

Decode from Base64 format

Simply enter your data then push the decode button.

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjYyYzY3NjY5M2Y2ZjNiNDhmYjU3ODhmMyIsIm5pY2tuYW1IIjoidnVsbiIsImlhdCI6MTY1NzE3Mzc1OSwiZXhwIjoxNjU3Nzc4NTU5fQ.ZBd17IHr0844eQDwHTJdaV6UMDAObJsCCvShkDLcNug

For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

ASCII — Source character set.

Decode each line separately (useful for when you have multiple entries).

Live mode OFF — Decodes in real-time as you type or paste (supports only the UTF-8 character set).

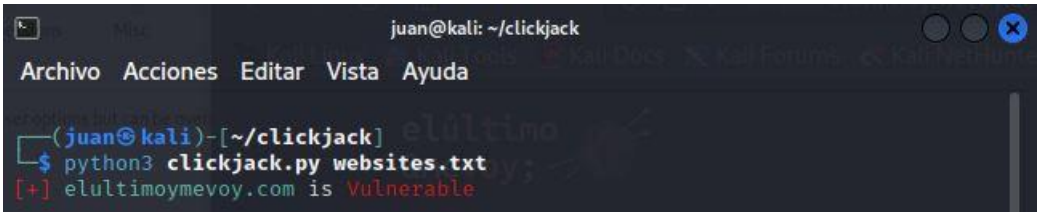
DECODE — Decodes your data into the area below.

{"alg":"HS256","typ":"JWT"}{"id":"62c676693f6f3b48fb5788f3","nickname":"vuln","iat":1657173759,"exp":1657778559}Aw^<%C J-n

Clickjacking

https://owasp.org/www-community/attacks/Clickjacking

Ya través de los escáneres de vulnerabilidades pudimos preveer que la pagina tal vez tuviera una vulnerabilidad de clickjacking, hemos usado la herramienta en Python de clickjack para saber si era vulnerable, y lo hemos comprobado usando clickbandit de burpsuite para generar un POC con nuestro target.



Mitigación clickjacking

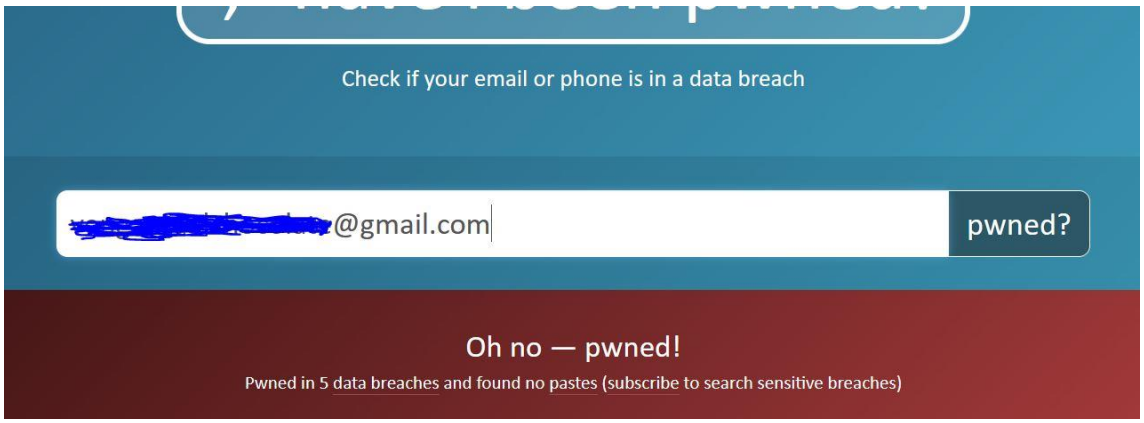
El mejor enfoque para prevenir los ataques de clickjacking es pedir al navegador que bloquee cualquier intento de cargar tu sitio web dentro de un iframe. Puedes hacerlo enviando la cabecera HTTP X-Frame-Options.

Recomendación

Para evitar recibir un ataque de osint/phishing lo mas adecuado es ocultar la máxima información posible sobre nuestras cuentas/personal data ... Establecer formularios a través de la pagina web u otras vías.

Al final de la página están los creadores, los cuales tienen un contacto en el que muestran un email de lo 5, 3 pueden encontrarse en data leaks de bases de datos o diferentes páginas web.

Usando haveibeenpwned



Conclusiones

Los resultados de esta prueba de penetración sobre elultimoymevoy.com en general es positivo, ya que el uso de gandi como web hosting aporta seguridad en cuanto a bastionado de la app, algunos firewalls montados como cowrie en el puerto 22 hacen difícil el acceso remoto, las resoluciones dns, no se muestra geolocalización, algunos aspectos de diseño en cuanto a vulnerabilidades me transmiten un diseño seguro y que se toman en serio la seguridad.